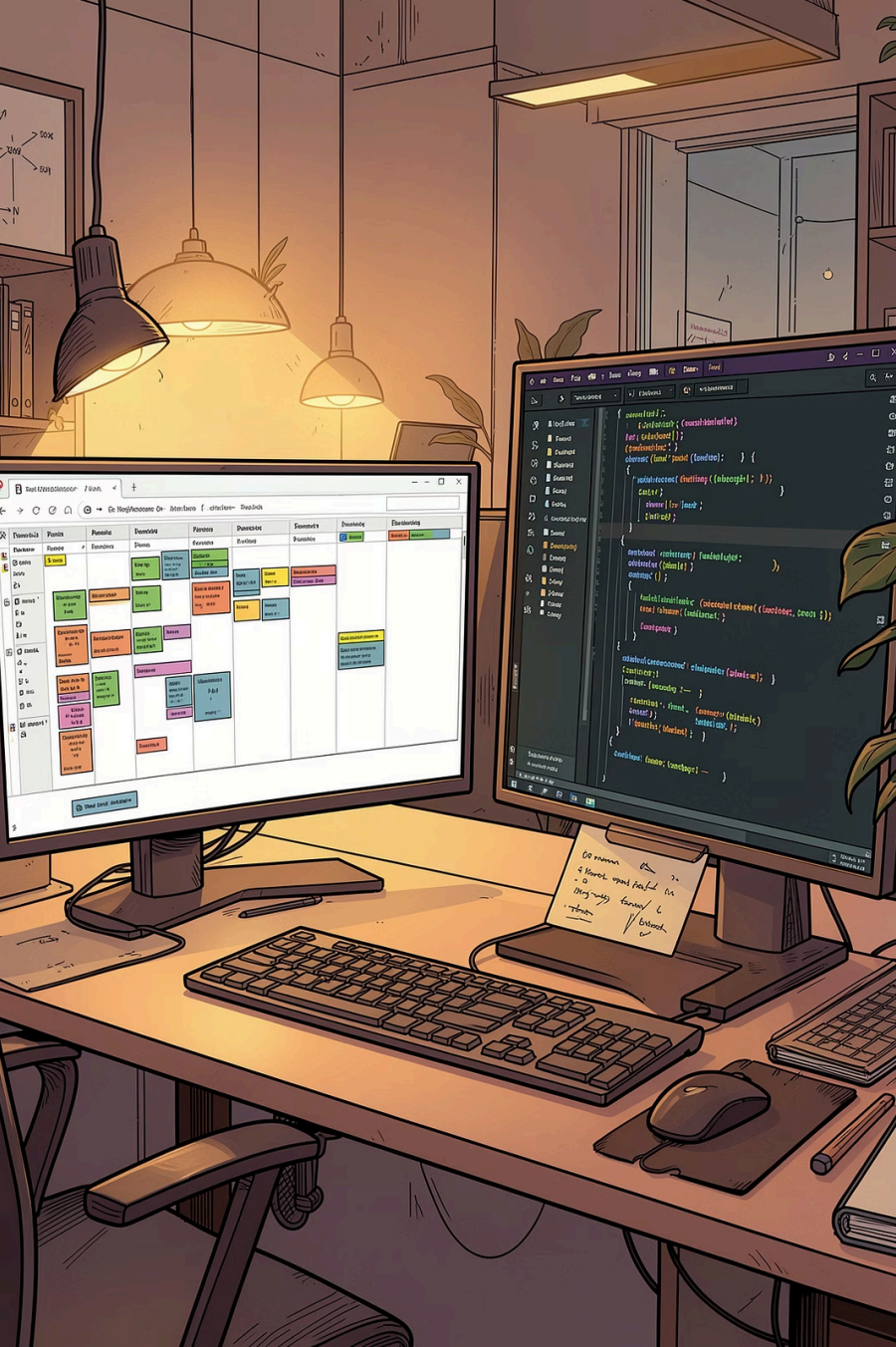




ToDo AFL – Lista de Tarefas Fullstack Colaborativa

Um aplicativo de lista de tarefas no estilo **Trello/Jira** com autenticação sem senha, backend em Python como fonte da verdade e Next.js como uma camada BFF segura.

FASTAPI

SQLITE

NEXT.JS 15

TYPESCRIPT

TAILWINDCSS

REDIS

O que o sistema faz

CRUD de tarefas

Cada tarefa tem **id**, **title**, **description**, **status** e **creation date** — operações completas de criar, ler, atualizar e excluir.

Autenticação sem senha

Autenticação por magic link + código OTP com gerenciamento de **JWT session** — sem necessidade de senha.

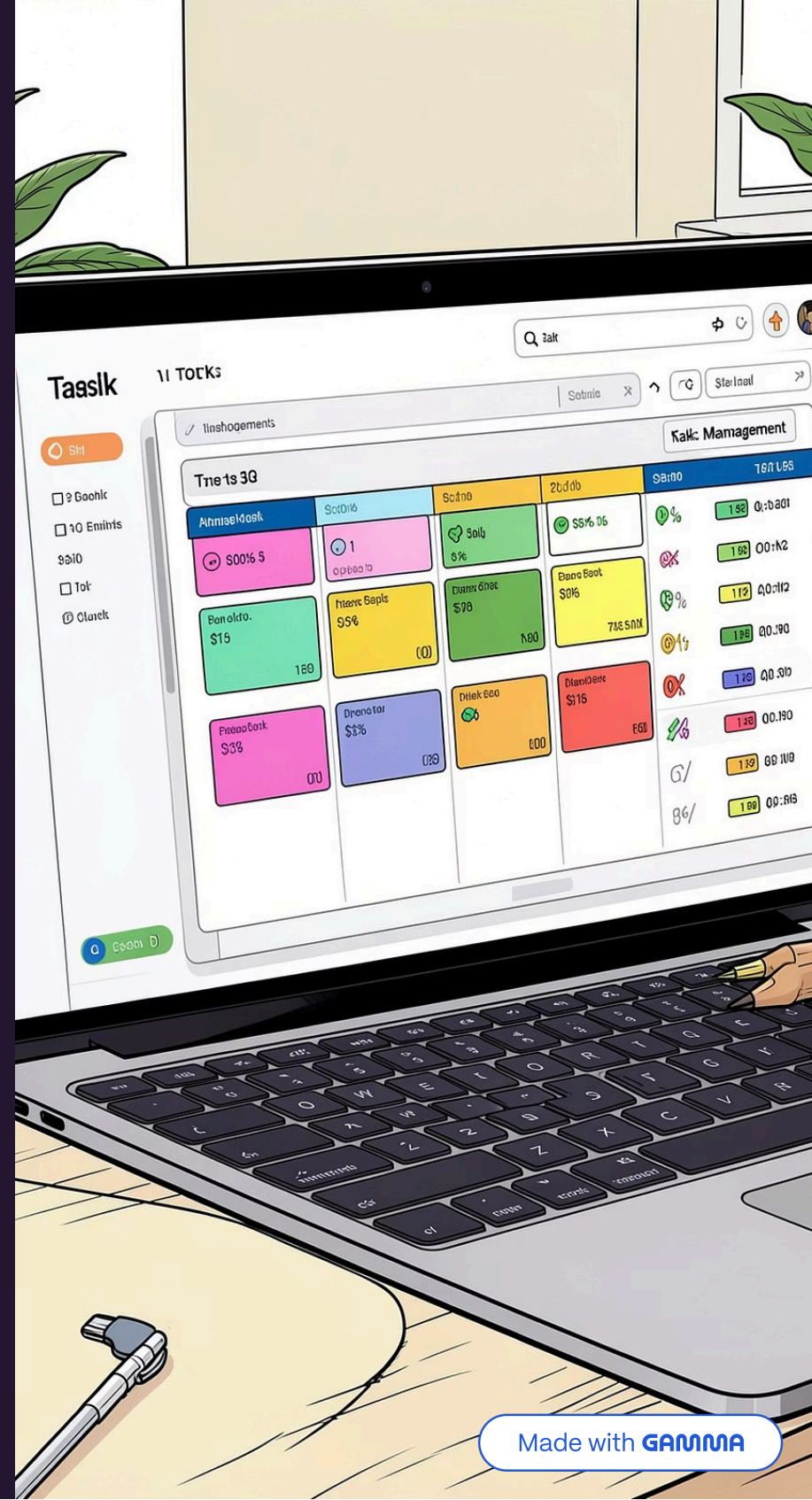
Controle de acesso

Cada usuário acessa **apenas as tarefas para as quais tem permissão** de visualizar — aplicado no nível do backend.

Interface Kanban

Um board no estilo **Trello/Jira** com colunas de arrastar e soltar, com persistência em SQLite.

Visão geral completa: [docs/01-visao-geral.md](#) · Estrutura: [docs/02-estrutura.md](#)



Quadro Kanban e Projetos

Quadro de Três Colunas

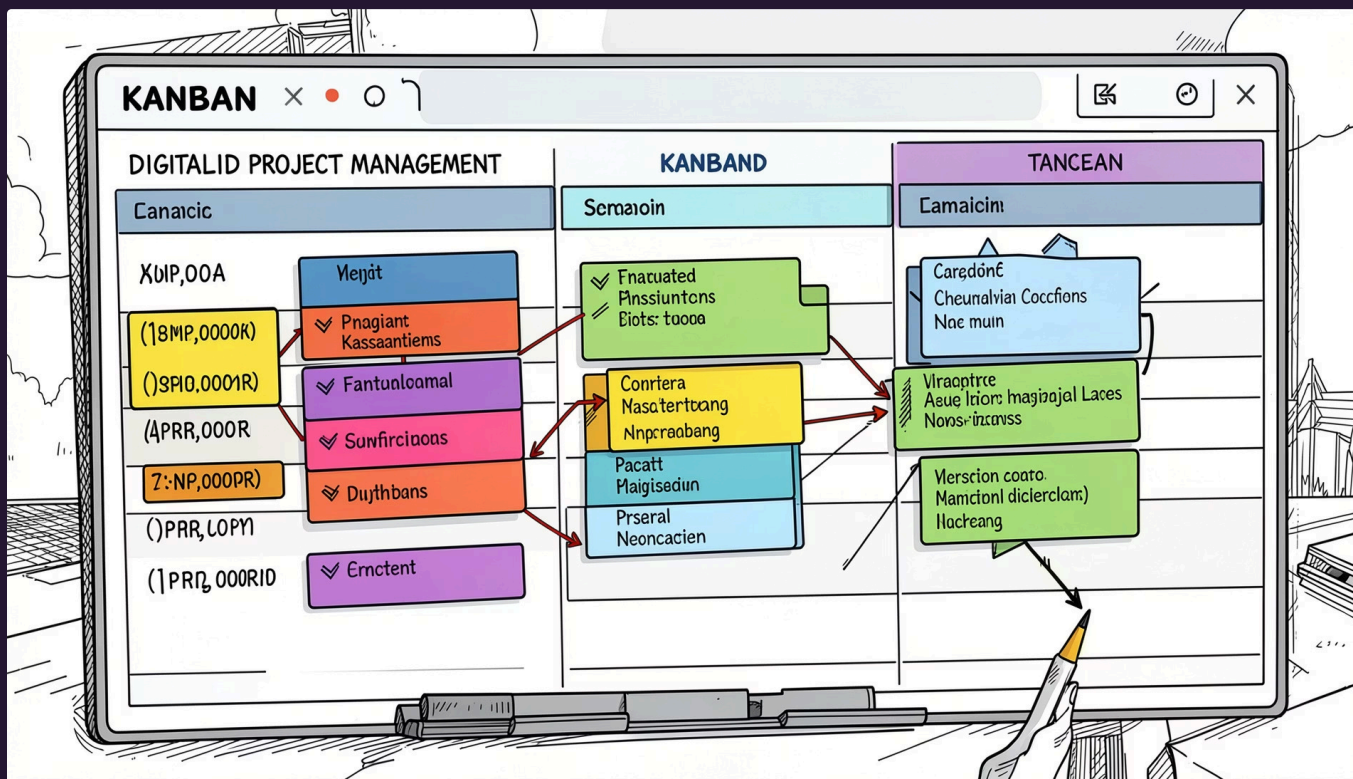
As tarefas fluem pelas colunas **Pending** / **In Progress** / **Done** com suporte completo a arrastar e soltar.

Projetos Aninhados

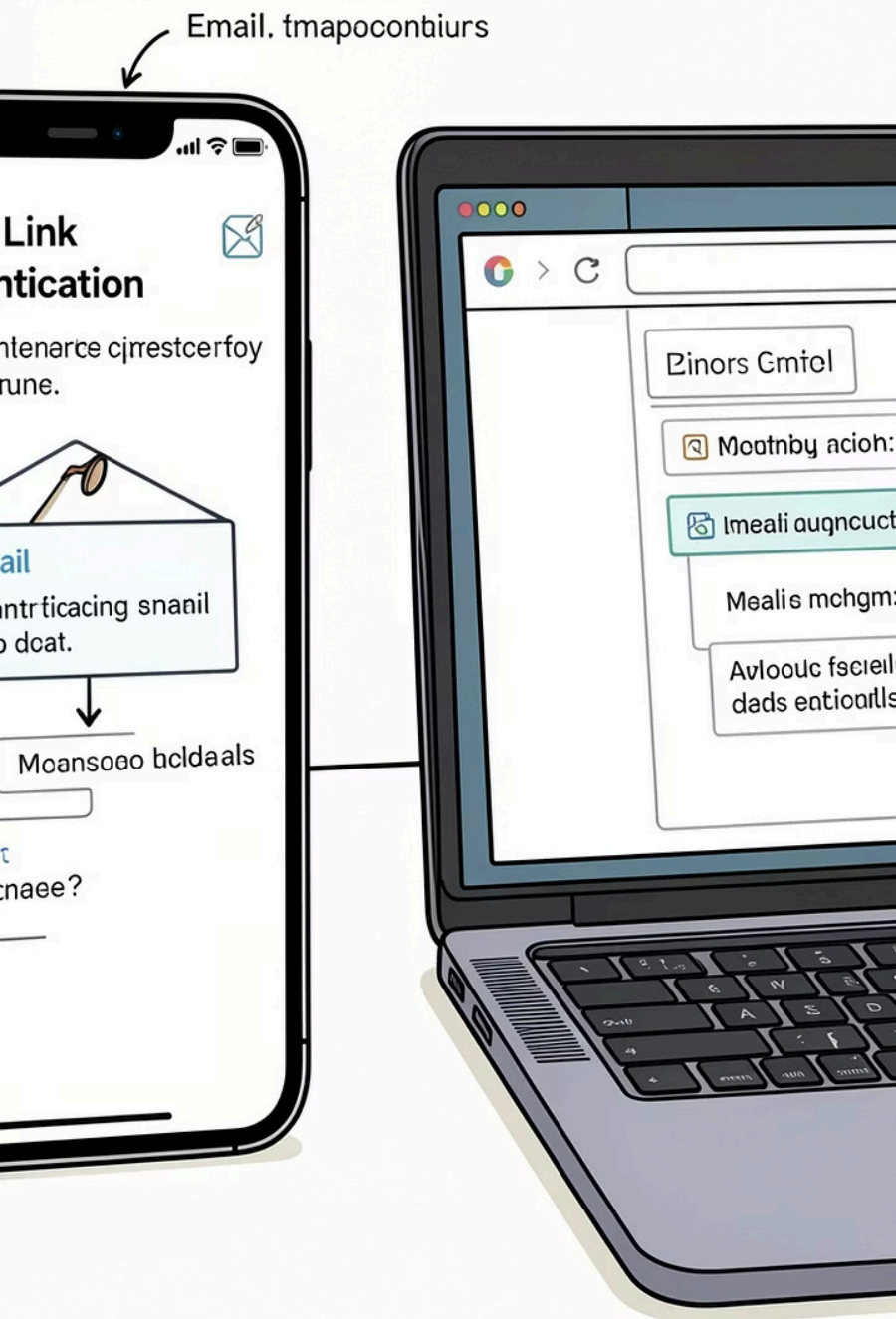
Projects agrupam tarefas e se tornam seu próprio quadro aninhado. Um cartão de projeto tem seu próprio status e pode ser arrastado entre colunas exatamente como uma tarefa.

Visibilidade da Colaboração

Cada cartão exibe o **criador** e todos os **membros atribuídos** por meio de avatares — mantendo toda a equipe alinhada em um olhar.



i Detalhes de projetos e colaboração: [docs/10-projetos-colaboracao.md](#)



Autenticação Sem Senha

O usuário informa seu e-mail e recebe um **link** + um **código de 6 dígitos**. Nenhuma senha é necessária.



Informar E-mail

O usuário envia seu endereço de e-mail na tela de login.



Receber Magic Link + OTP

Um link e um código de 6 dígitos são enviados para a caixa de entrada — uso único e com tempo limitado.



Confirmar e Auto-Registrar

O **primeiro acesso cria a conta** automaticamente após a confirmação — sem fluxo separado de cadastro.

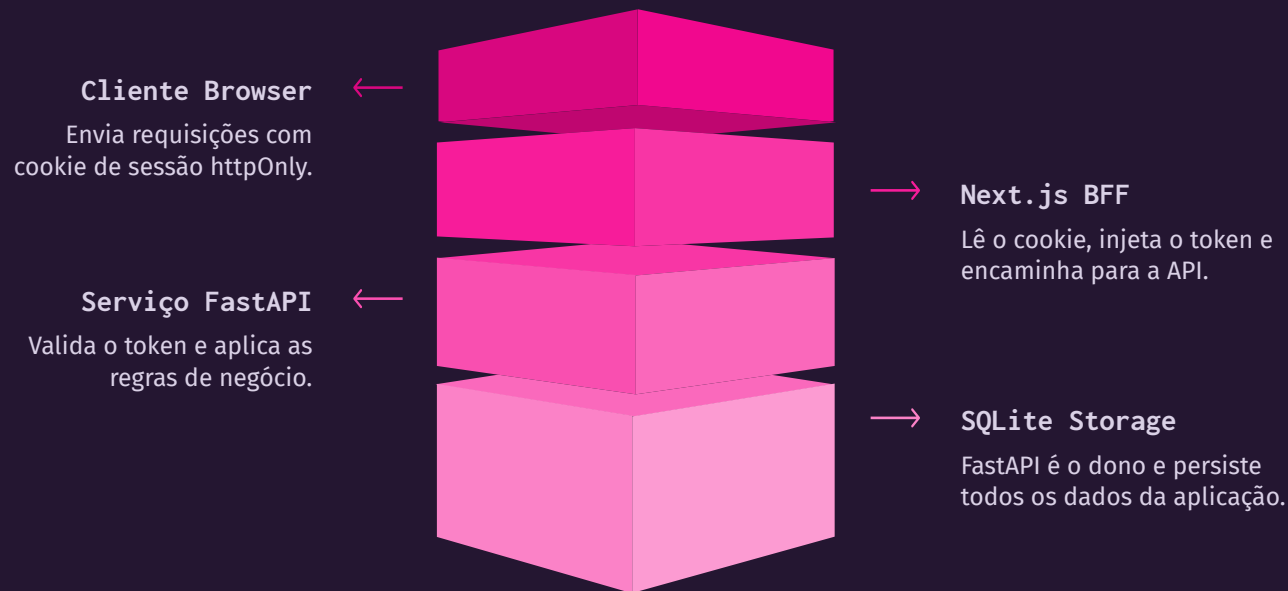


Sessão JWT Emitida

O backend emite um JWT após a confirmação. Funciona em **múltiplos dispositivos**: solicite no PC, confirme no celular.

Dois modos disponíveis: **Backend Python** (self-hosted) ou **Python + Supabase Auth**. Detalhes: [docs/09-autenticacao.md](#) · [docs/04-configurar-supabase.md](#)

Arquitetura: Python + BFF



FastAPI – Fonte da Verdade

FastAPI valida cada requisição e é o dono de todos os dados armazenados em **SQLite**. Nenhuma lógica de dados vive no frontend.

Next.js como BFF

O token de sessão fica armazenado em um **cookie `httpOnly`** — nunca exposto ao JavaScript do navegador. O navegador se comunica apenas com o Next.js (same-origin), que injeta o token e faz proxy das requisições para Python.

- ✓ Esse padrão elimina totalmente o roubo de token por ataques de XSS.

Segurança & BFF: [docs/13-seguranca.md](#)

Decisões técnicas: [docs/14-decisoes-tecnicas.md](#)

Colaboração & Permissões

Um **projeto** é a unidade de compartilhamento. O proprietário configura permissões granulares **por membro**:

Mover Projeto

Controle quem pode arrastar o **cartão do projeto** entre colunas de status no quadro.

Mover Tarefas

Controle quem pode fazer **arrastar e soltar** em cartões de tarefa individuais dentro do projeto.

Criar / Editar / Excluir

Controle granular sobre quem pode **escrever ou remover** tarefas dentro do projeto.

Alertas por Email

Escolha quem **recebe notificações** na criação de tarefas ou em mudanças de status.

Política de Remoção

Ao remover um membro: **revogar o acesso** completamente ou **mantê-lo como proprietário** de suas tarefas existentes.

📌 Designar uma pessoa para uma tarefa concede acesso a ela — mesmo para tarefas fora de um projeto.

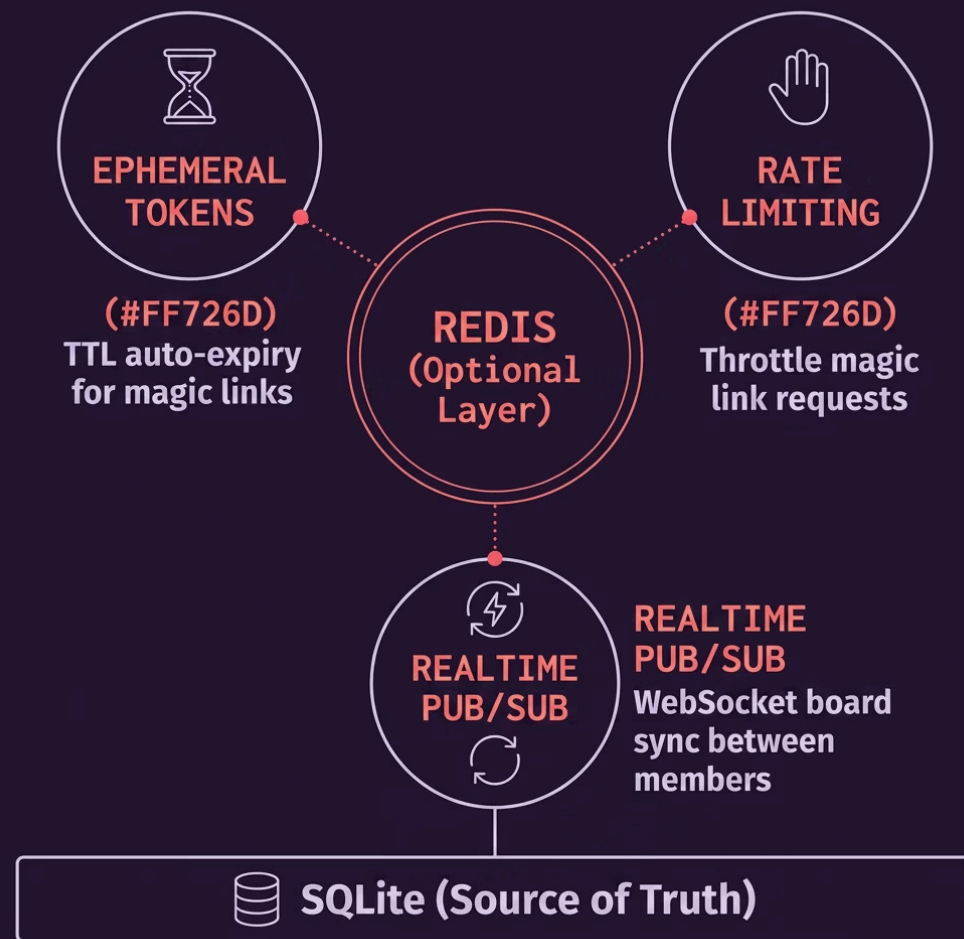
Camada Redis (Opcional) & Realtime

SQLite primeiro, Redis como acelerador

SQLite é sempre a fonte da verdade. Redis é uma **camada opcional de aceleração** — todo o sistema funciona sem ele, com fallback automático.

- **Tokens de login efêmeros** com TTL automático — magic links expiram corretamente
- **Limitação de taxa** no envio de magic links — evita abuso
- **Atualizações em tempo real** via Pub/Sub + WebSocket — o board se atualiza ao vivo para todos os membros

📘 Detalhes de Redis e realtime: [docs/05-redis-realtime.md](#)



Segurança



Expiração de JWT

As sessões expiram automaticamente. Magic links e códigos OTP são de **uso único** com tentativas limitadas.



Validação de Associação

O acesso é validado pela **membership no backend**. O `user_id` sempre vem do token — nunca do frontend.



Validação de JWKS

Os tokens do Supabase são validados usando a **chave pública (JWKS)** — sem segredos compartilhados.



Fortalecimento em Produção

O backend nunca expõe segredos nas respostas. Exige **SMTP + strong JWT_SECRET** em ambientes de produção.

Guia de segurança: [docs/13-seguranca.md](#) · Configuração de ambiente: [docs/03-configuracao-env.md](#)

Testes Automatizados

Três camadas de teste com **CI no GitHub Actions** acionado a cada push:

104

Testes de Backend

pytest — cobertura de auth, CRUD, permissions, alerts, Redis e realtime

21

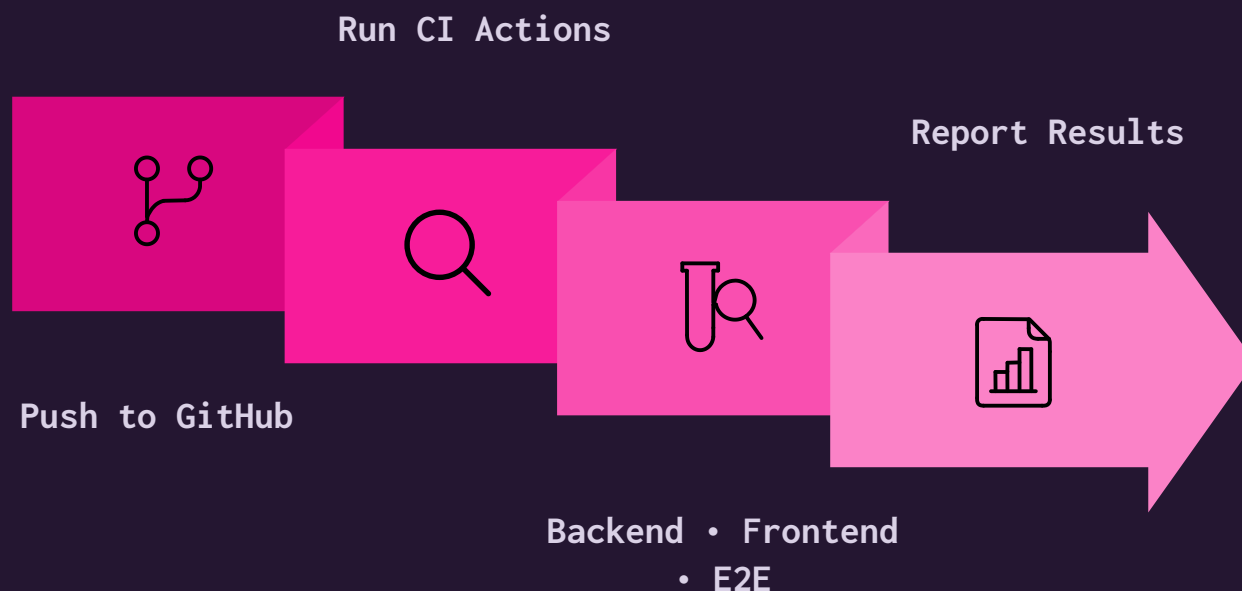
Testes de Frontend

vitest — client de API (BFF) e testes em nível de componente

16

Testes E2E

Playwright — fluxos completos de ponta a ponta cobrindo UI, HTTP e banco de dados



Estratégia de Cobertura de Testes

A abordagem em três camadas garante confiança em todos os níveis da stack — da lógica unitária isolada até jornadas completas do usuário na UI real e no banco de dados.

Documentação de testes:

[tests/README.md](#) · Produção & Docker: [docs/15-producao.md](#)

Como Executar

Configuração do Backend

```
# In backend/  
python -m venv .venv  
pip install -r requirements.txt  
alembic upgrade head  
uvicorn app.main:app --reload --port 8000
```

Configuração do Frontend

```
# In frontend/  
npm install && npm run dev  
# http://localhost:3000
```

- ✔ Sem SMTP configurado? O magic link e o código OTP aparecem diretamente na tela — perfeito para desenvolvimento local.

Guias Passo a Passo

→ Passo a passo do backend

[docs/06-rodar-backend.md](#)

→ Passo a passo do frontend

[docs/07-rodar-frontend.md](#)

→ Acesso à rede em múltiplos dispositivos

[docs/08-acesso-rede-multidevice.md](#)